

SGSI-REG-003 — Declaración de Aplicabilidad (SoA)

Organización: Atalaya Gestión Patrimonial SL

Versión: 1.8 | Estado: Revisión documental pendiente de aprobación | Revisión: 20/09/2026 | Aprobación: pendiente conforme a DOC-002 §4. Fecha de corte sin cambios. Clasificación: Interna

Criterio de inclusión (SGSI-DOC-004 §6): todo control aplicable debe estar justificado por al menos un riesgo del registro (RSC-xxx), un requisito legal/contractual o una obligación de la propia norma. Un control sin justificación es candidato a exclusión.

Las diez exclusiones describen el diseño de corte y requieren revisión individual al cambiar el alcance. La ausencia de desarrollo propio no basta como argumento universal para requisitos de aplicaciones, arquitectura o enmascaramiento. La incorporación futura de IA no implica activación automática de todas ellas.

Estados de implantación (vocabulario común con SGSI-REG-001, valores exactos en mayúsculas): IMPLEMENTADO (opera y deja evidencia registrada) / PARCIAL (opera sin evidencia registrada o solo en parte del alcance) / PLANIFICADO (no opera todavía) / NO APLICA. Regla de coherencia: el estado de un control del Anexo A es el del control menos avanzado del registro que lo soporta (SGSI-REG-001, hoja «Controles»); ningún control puede figurar más avanzado que su tratamiento. Excepción declarada: los controles físicos preexistentes a la implantación del SGSI (DOC-001 §9) figuran como PARCIAL aunque su tratamiento esté planificado, porque el medio existe y opera; lo que falta es la evidencia registrada de su ejecución.

Nota sobre el estado de implantación a fecha de corte (24/07/2026): la SoA refleja el diseño del SGSI antes del primer ciclo de implantación. Reparto: IMPLEMENTADO 1 · NO APLICA 10 · PARCIAL 11 · PLANIFICADO 71. El único control en estado IMPLEMENTADO es A 8.14 (redundancia de instalaciones), operado por el proveedor cloud y acreditado por su SLA: no lo soporta ningún control del registro y sobre esa base se retiene RSC-017. Ningún control del registro de riesgos (SGSI-REG-001) ha alcanzado ese estado. Los controles físicos preexistentes (perímetro, suministro, protección ambiental, contacto con grupos de interés) figuran como PARCIAL y no como IMPLEMENTADO: operan, pero su ejecución no deja evidencia registrada y por tanto no alcanzan cobertura efectiva según SGSI-DOC-004 §6. Esa distinción no es un matiz formal: es el hallazgo central de la revisión v1.1 (RSC-018) y está registrada como deuda de diseño HD-01 y HD-03 en SGSI-REG-006. Se aprueba el sistema para empezar a implantarlo, no un sistema ya operado.

Cambios v1.1: incorporación de los escenarios RSC-018 a RSC-025 (fallos de ejecución y operativa material) a las justificaciones de aplicabilidad; nueva columna de trazabilidad a los controles individuales del registro (SGSI-REG-001, hoja «Controles»). Sin altas ni bajas de controles del Anexo A. Corrección de coherencia v1.1: unificación del vocabulario de estado con SGSI-REG-001 y aplicación de la regla de coherencia entre la SoA y el registro de riesgos (93 estados recalculados). Hallazgo del propio proceso de trazabilidad; registrado en SGSI-REG-006.

Cambios v1.2: verificación documental de cierre, adoptada en la misma sesión. Reclasificación de la traza del control A 8.6 como deuda documental (la deuda pasa de nueve controles a diez, HD-01); concreción de la evidencia y del alcance del control A 8.14; alta de un cuadro de trazabilidad en la hoja «Resumen». Sin altas ni bajas de controles del Anexo A, sin cambios de aplicabilidad y sin cambios de estado de implantación.

Cambios v1.3: revisión de coherencia cruzada. Retirada de la etiqueta de deuda documental del control 5.23 (trazado a C-052); corrección de la referencia de retención del control 8.10 a SGSI-DOC-002 §5.1; y declaración expresa del control 8.14 como excepción a la regla de coherencia de estados por estar acreditado mediante contrato de tercero. Sin cambios en la aplicabilidad ni en las justificaciones.

Cambios v1.4: corrección del alcance declarado de la exclusión por desarrollo. Esta portada enumeraba nueve de los diez controles no aplicables (omitía 8.11, enmascaramiento de datos) y la nota de caducidad del control 8.30 declaraba un alcance de reactivación (8.25 a 8.29) menor que el de la causa que la motiva. Los diez controles no aplicables se excluyen por la misma causa y los diez se reactivan si la Fase 2 entra en alcance. Se actualiza además la cabecera de versión, que no recogía la revisión v1.3. Sin cambios en la aplicabilidad, en las justificaciones ni en los estados.

Cambios v1.5: revisión de coherencia cruzada de cierre. Corrección de cuatro referencias que apuntaban a DOC-001 §6 (Partes interesadas) debiendo apuntar a DOC-001 §9 o a ESC-001 §6, y de la traza de 8.34, que citaba DOC-010 §4 (no conformidad) en lugar de §2 (auditoría). Actualización del estado de REG-005, que figuraba «en elaboración» estando vigente y aprobado a la misma fecha de corte. Reasignación de C-050 y C-060 de 7.14 a 7.10: el papel es soporte de almacenamiento y no equipo. Retirada de C-005 de 8.1 (configura un servicio, no un dispositivo) y de C-047 y C-036 de 8.17 (registran eventos, no sincronizan relojes); ambos controles del Anexo A pasan a soportarse en el anexo del MSP (DOC-006 §5), que en esta misma revisión incorpora la sincronización horaria común y el borrado certificado de equipos retirados. Retirada de C-021 de 7.12. Alta de A 8.7 y A 8.19 en la deuda documental, que pasa de diez a doce controles: el antivirus y la instalación de software estaban trazados al anexo del MSP, que no los regula. Razonamiento expreso de por qué DOC-006 §3 no soporta 6.1 y por qué C-049 no cierra 7.5. Y declaración de adaptación en once filas donde el Anexo A no contiene control propio para lo que el registro trata.

Declaración de adaptación (v1.5): El Anexo A de SGSI-REG-003-2026 no contiene control específico para la recogida de

valores, para la seguridad de un desplazamiento en destino, para la supervisión de la posición de un vehículo ni para normas acordadas con personas que el alcance excluye expresamente como usuarios (DOC-001 §7.3). Esos controles del registro se sostienen por

El riesgo que tratan, no por el control que están y se traza el control del Anexo A más próximo dejando constancia de que el mapeo es una adaptación. Se declara porque forzar el encaje en silencio es lo que convierte una SGA en un ejercicio de relleno. Es la misma

razón por la que DOC-006 §8 declara que su política no cubre a los invitados de la familia en lugar de estirar la tabla T1-T3.

Cambios v1.6: trazabilidad del control 5.34 a SGSI-REG-008 (Registro de Actividades de Tratamiento), SGSI-DOC-011 (ponderación del interés legítimo) y SGSI-DOC-012 (EIPD), y al hallazgo HD-08 que ese bloque produjo. Corrección de la referencia de 5.31 a SGSI-REG-005, que citaba la v1.3 estando vigente la v1.4. Sin cambios en la aplicabilidad ni en los estados de implantación. Cambios v1.7: control 8.21 (seguridad de los servicios de red) reclasificado a deuda documental. DOC-006 v1.5 retiró su propio anexo del MSP (§5) como soporte de este control, en la verificación cruzada de agosto de 2026; sin otro documento o control del registro que lo justifique, pasa a «Sin soporte documental» y se incorpora a HD-01 (SGSI-REG-006), que sube de doce a trece controles. Sin cambios en la aplicabilidad ni en los estados de implantación. Aprobado por el Comité de Seguridad Convergente el 22/08/2026 (acta del Comité de 22/08/2026).

Revisión de septiembre: retirada de C-039/C-044 de A.8.15; C-044 se traza a A.5.33. Se conservan los 93 controles, estados y aplicabilidad de corte. Las exclusiones deben reevaluarse individualmente al definir la herramienta de IA; no se reactivan las diez automáticamente. A.8.26/A.8.27/A.8.11 quedan señaladas para revisión de justificación antes de afirmar conformidad completa.

Historial 1.8 | 20/09/2026 | Autor del caso | Corrección de coherencia y legibilidad. Deltas en correcciones_2026-09.md. Sin aprobación formal ni eficacia operativa declarada.

Control	Nombre	Aplica	Justificación (riesgo / requisito que lo exige)	Implementación / referencia	Propietario del control	Estado	Controles (SGSI-REG-001)
5.1	Políticas de seguridad de la información	Si	Requisito 5.2 de la norma; base de todo el sistema.	SGSI-DOC-003 (dos niveles: declaración + desarrollo)	Dirección General	PARCIAL	DOC-003
5.2	Roles y responsabilidades de seguridad	Si	Gobernanza dual e informal del contexto: sin roles formalizados el SGSI no tiene dueño (DOC-001 §5).	DOC-003 §6: Comité, Responsable SGSI, repr. de la propiedad	Dirección General	PARCIAL	DOC-003 §6
5.3	Segregación de funciones	Si	RSC-014; una estructura de nueve personas, de las que siete son empleados, exige compensatorios explícitos. Refuerzo v1.1: RSC-019 (transporte de efectivo sin doble validación).	DOC-003 §6.2; DOC-007 R3 (cuatro ojos)	Dirección General	PLANIFICADO	C-038
5.4	Responsabilidades de la dirección	Si	El principal es el mayor escéptico del sistema: el compromiso visible es condición de viabilidad.	Declaración firmada + sesión presencial (DOC-003 §3, §7)	Dirección General	PARCIAL	DOC-003 §3, §7
5.5	Contacto con las autoridades	Si	RSC-001: incidentes con dimensión penal probable; entorno de criminalidad organizada.	DOC-009 §4 (S1): DG con asesoría legal	Dirección General	PLANIFICADO	DOC-009 §4
5.6	Contacto con grupos de interés especial	Si	Necesidad de inteligencia de amenazas del entorno local y del perfil (grandes patrimonios). DEUDA v1.1: control declarado aplicable sin soporte documental identificado; pendiente de asignar documento o control en el registro.	Jefe de seguridad: red profesional y fuentes del sector	Jefe de seguridad	PARCIAL	Sin soporte documental
5.7	Inteligencia de amenazas	Si	Fuente obligada de identificación de escenarios (DOC-004 §5.1); RSC-001, RSC-009, RSC-015. Refuerzo v1.1: RSC-022 (viajes sin evaluación de destino).	Cuaderno de indicios + línea base OSINT + fuentes externas	Jefe de seguridad	PLANIFICADO	C-007, C-029, C-056
5.8	Seguridad de la información en proyectos	Si	Cambios previstos (obras, nuevos proveedores, Fase 2 del caso) deben evaluar riesgos antes de operar.	DOC-004 §8: nueva interfaz exige escenarios previos	Dirección General	PARCIAL	DOC-004 §8
5.9	Inventario de información y activos	Si	Sin inventario no hay escenario completo; insumo del análisis (DOC-004 §3.2). Refuerzo v1.1: RSC-023 (papel disperso sin inventario), RSC-024 (equipos sin inventario técnico).	Inventario de activos y soportes, anexo al REG-001	Dirección General	PLANIFICADO	C-048, C-064
5.10	Uso aceptable de la información y activos	Si	RSC-002, RSC-004: normas de uso para plantilla y reglas acordadas con familia y círculo. Refuerzo v1.1: RSC-021 (invitados no verificados introducidos por los socios).	DOC-008 §2-3; acuerdos ACU-001/002	Repr. de la propiedad (ámbito familiar) / DG	PLANIFICADO	C-001, C-005, C-006, C-045
5.11	Devolución de activos	Si	Rotación de doméstico y contratas; bajas como ventana de riesgo (RSC-011).	DOC-006 §6	Dirección General	PLANIFICADO	DOC-006 §6
5.12	Clasificación de la información	Si	La regla 'rutinas = Restringida' es el eje de protección de la familia (RSC-001, RSC-002). Refuerzo v1.1: RSC-019 (existencia del movimiento como Restringida), RSC-022 (itinerario), RSC-023.	DOC-002 §5 (4 niveles)	Dirección General	PLANIFICADO	C-031, C-041, C-050
5.13	Etiquetado de la información	Si	Necesario para que la clasificación opere en una plantilla pequeña sin modificaciones.	DOC-002 §5; plantillas de documento	Dirección General	PLANIFICADO	DOC-002 §5
5.14	Transferencia de información	Si	RSC-006, RSC-007, RSC-016: el flujo España-Irlanda es la interfaz crítica. Refuerzo v1.1: RSC-022 (difusión del itinerario).	Canal cifrado con asesores; DOC-007; O2	Resp. financiero	PLANIFICADO	C-012, C-015, C-016, C-017, C-020, C-031
5.15	Control de acceso	Si	RSC-008, RSC-011: acceso por rol al repositorio y a los sistemas. Refuerzo v1.1: RSC-023 (control de acceso por rol a la documentación digitalizada).	Política de acceso por rol (repositorio, M365, NAS)	Dirección General	PLANIFICADO	C-050
5.16	Gestión de identidad	Si	Cuentas nominales para plantilla, MSP y círculo (fin de cuentas compartidas/personales). RSC-005, RSC-008.	Alta/baja nominal gestionada con el MSP	Dirección General	PLANIFICADO	C-014
5.17	Información de autenticación	Si	RSC-010, RSC-014: la voz no autentica; credenciales del principal bajo custodia formalizada.	DOC-007 R2; gestor de credenciales corporativo	Resp. financiero	PLANIFICADO	C-014, C-018, C-059, C-061, C-062, C-063
5.18	Derechos de acceso	Si	RSC-005: poderes de 2015 sin revisar = derechos de acceso legales sin recertificar.	Revisión semestral T1 / anual T2 (DOC-006 §3); revisión de poderes	Dirección General	PLANIFICADO	C-013, C-019 — C-013 (revisión de poderes notariales) se traza aquí por adaptación declarada: son facultades de representación, no derechos de acceso lógico.
5.19	Seguridad en las relaciones con proveedores	Si	Terceros con acceso real inventariados en ESC-001 §5 y clasificados por acceso en DOC-006 §2 (niveles T1-T3); RSC-008, RSC-011. Refuerzo v1.1: RSC-020 (obras y contratas sin planificación ni acreditación).	DOC-006 (clasificación T1-T3 por acceso real)	Dirección General	PLANIFICADO	C-042
5.20	Requisitos de seguridad en acuerdos con proveedores	Si	Ningún contrato actual tiene cláusulas de seguridad; O1. Refuerzo v1.1: RSC-020 (contratas sin cláusulas ni acreditación).	Anexos contractuales por nivel (DOC-006 §3, §5)	Dirección General	PLANIFICADO	C-021, C-042
5.21	Cadena de suministro TIC	Si	El MSP subcontrata y revende servicios cloud; RSC-008.	Prohibición de subcontratar sin autorización (DOC-006 §5)	Dirección General	PLANIFICADO	DOC-006 §5
5.22	Seguimiento y revisión de servicios de proveedores	Si	RSC-008, RSC-009: el MSP administra sin supervisión. Refuerzo v1.1: RSC-024 (obsolescencia técnica del MSP sin verificación independiente).	Supervisión del jefe de seguridad + verificación técnica anual	Dirección General	PLANIFICADO	C-021, C-051
5.23	Seguridad en servicios en la nube	Si	M365 en configuración por defecto (ESC-001 §6); RSC-013.	Revisión de configuración M365 con el MSP (línea base)	Dirección General	PLANIFICADO	C-052 (PT-15); línea base pendiente de documentar
5.24	Planificación de la gestión de incidentes	Si	Lección del cuasi-incidente fundacional: sin canal ni mandato, los indicios no se juntan.	DOC-009 (procedimiento convergente completo)	Jefe de seguridad	PLANIFICADO	C-002
5.25	Evaluación y decisión sobre eventos	Si	Correlación físico-digital con umbral bajo deliberado (RSC-001). Refuerzo v1.1: RSC-021 (cruce de registro de visitas con el cuaderno de indicios).	DOC-009 §5: revisión semanal del cuaderno de indicios	Jefe de seguridad	PLANIFICADO	C-003, C-047
5.26	Respuesta a incidentes	Si	RSC-001, RSC-006: respuesta definida por severidad.	DOC-009 §4 (S1-S4)	Jefe de seguridad	PLANIFICADO	DOC-009 §4
5.27	Aprendizaje de los incidentes	Si	Cierre con informe y re-evaluación de escenarios (mejora del registro).	DOC-009 §6	Jefe de seguridad	PLANIFICADO	DOC-009 §6
5.28	Recogida de evidencias	Si	Dimensión penal probable de los incidentes S1 (extorsión, intrusión).	DOC-009 §4: preservación para denuncia	Jefe de seguridad	PLANIFICADO	DOC-009 §4
5.29	Seguridad de la información durante disrupciones	Si	La protección de la familia no se suspende por una caída de sistemas. DEUDA v1.1: control declarado aplicable sin soporte documental identificado; pendiente de asignar documento o control en el registro.	Modo degradado documentado (contactos y órdenes en papel controlado)	Dirección General	PLANIFICADO	Sin soporte documental
5.30	Preparación de las TIC para la continuidad	Si	RSC-013, RSC-017: dependencia operativa del correo y el repositorio.	Copias 3-2-1 + prueba de restauración (PT-10)	Dirección General	PLANIFICADO	C-032, C-033 (PT-10)
5.31	Requisitos legales, reglamentarios y contractuales	Si	Doble jurisdicción ES/IE; RGPD/LOPDGDD; confidencialidad de pólizas.	SGSI-REG-005 v1.4, vigente y aprobado por el Comité (24/07/2026)	Dirección General	PARCIAL	REG-005
5.32	Derechos de propiedad intelectual	Si	Alcance menor pero real: licencias de software gestionadas por el MSP. DEUDA v1.1: control declarado aplicable sin soporte documental identificado; pendiente de asignar documento o control en el registro.	Inventario de licencias (MSP)	Dirección General	PLANIFICADO	Sin soporte documental
5.33	Protección de registros	Si	Registros del SGSI y de verificación de órdenes como evidencia (DOC-007 R6). Refuerzo v1.1: RSC-019 (trazabilidad del movimiento de efectivo), RSC-023.	Retención definida en DOC-002	Dirección General	PLANIFICADO	C-039, C-044, C-048, C-058

Control	Nombre	Aplica	Justificación (riesgo / requisito que lo exige)	Implementación / referencia	Propietario del control	Estado	Controles (SGSI-REG-001)
5.34	Privacidad y protección de datos personales	Sí	Datos de menores y del personal; RGPD. Refuerzo por RSC-003. Desarrollo completo en SGSI-REG-008 (Registro de Actividades de Tratamiento), SGSI-DOC-011 (ponderación del interés legítimo) y SGSI-DOC-012 (EIPD), que identifican el hallazgo HD-08 (MSP como encargado del tratamiento de facto sin contrato conforme al art. 28 RGPD; SGSI-REG-006).	Registro de tratamientos (SGSI-REG-008); ponderación del interés legítimo (SGSI-DOC-011) y evaluación de impacto (SGSI-DOC-012); asesoría DPO externa.	Dirección General	PLANIFICADO	C-056
5.35	Revisión independiente de la seguridad	Sí	Sin capacidad interna de verificación: revisión externa anual comprometida. Refuerzo v1.1: RSC-024 (verificación técnica independiente anual del MSP).	Verificación técnica independiente + auditoría interna externalizada	Dirección General	PLANIFICADO	C-051
5.36	Cumplimiento de políticas y normas	Sí	Cierre del ciclo: revisión mensual de registros (DOC-007) y supervisión del Comité. Refuerzo v1.1: RSC-018 (lista de verificación de cierre firmada).	Revisiones del Comité; indicadores de O1-O7	Dirección General	PLANIFICADO	C-034
5.37	Procedimientos operativos documentados	Sí	Operativa del MSP y de seguridad física documentada para no depender de personas. Refuerzo v1.1: RSC-018 (procedimiento de cierre), RSC-025 (protocolo de puntualidad).	Procedimientos operativos con el MSP	Dirección General	PLANIFICADO	C-034, C-053
6.1	Investigación de antecedentes	Sí	T1/T2 con acceso a la familia (DOC-006 §3); proporcional y conforme a derecho. DEUDA v1.1: DOC-006 §3 exige la verificación previa de idoneidad pero no establece su procedimiento —qué se comprueba, con qué fuentes, quién la conserva y durante cuánto—, de modo que declara el requisito y no lo soporta. Pendiente de procedimiento propio o de control en el registro.	Verificación previa documentada por nivel	Dirección General	PLANIFICADO	Sin soporte documental
6.2	Términos y condiciones de empleo	Sí	Obligaciones de confidencialidad desde el contrato; hoy inexistentes en parte de la plantilla. DEUDA v1.1: control declarado aplicable sin soporte documental identificado; pendiente de asignar documento o control en el registro.	Cláusulas tipo en contratos (revisión legal)	Dirección General	PLANIFICADO	Sin soporte documental
6.3	Concienciación, educación y formación	Sí	RSC-001, RSC-004, RSC-016: el eslabón humano es el vector principal. O5. Refuerzo v1.1: RSC-021 (norma de aviso de invitados acordada con los hijos).	Plan por rol + sesión familiar + sesión del círculo	Dirección General	PLANIFICADO	C-001, C-045 — C-001 y C-045 (normas acordadas con la familia) se trazan aquí por adaptación declarada: la familia no es personal sujeto al SGSI (DOC-001 §7.3).
6.4	Proceso disciplinario	Sí	Consecuencias definidas sin criminalizar el error de buena fe (DOC-003 §8).	Remisión al régimen laboral y a acuerdos	Dirección General	PARCIAL	DOC-003 §8; régimen laboral
6.5	Responsabilidades tras la finalización	Sí	Bajas de doméstico/contratas como ventana de riesgo (RSC-011).	DOC-006 §6: recordatorio escrito de obligaciones	Dirección General	PLANIFICADO	DOC-006 §6
6.6	Acuerdos de confidencialidad	Sí	Círculo de confianza sin NDA (RSC-004); terceros T1-T3.	ACU-001/002 y anexos por nivel (DOC-006)	Dirección General	PARCIAL	C-011
6.7	Trabajo remoto	Sí	Asesores y asistente operan en remoto y en viaje; RSC-012. Refuerzo v1.1: RSC-022 (personal y familia operando fuera del perímetro en viaje).	DOC-008 §4 (V5-V7); acceso remoto cifrado	Dirección General	PLANIFICADO	C-029 — C-029 (ficha de seguridad de destino) se traza aquí por adaptación declarada; su encaje principal es 5.7.
6.8	Notificación de eventos de seguridad	Sí	Canal único con regla de no represalia; incluye a la familia (RSC-001).	DOC-009 §3	Jefe de seguridad	PLANIFICADO	C-002
7.1	Perímetros de seguridad física	Sí	Residencia y oficina; madurez física previa alta que el SGSI integra, no duplica. Refuerzo v1.1: RSC-018 (contactos en aberturas), RSC-022, RSC-025 (puntos de espera).	Perímetro existente de la finca; zonificación PT-08	Jefe de seguridad	PARCIAL	C-030, C-035, C-054, C-057 — perímetro preexistente en operación (DOC-001 §9); sin evidencia registrada — C-030 y C-054 (reconocimiento en destino y puntos de espera) se trazan aquí por adaptación declarada: actúan fuera del perímetro propio.
7.2	Entrada física	Sí	RSC-011: registro y acompañamiento por zonas. Refuerzo v1.1: RSC-020 (acompañamiento de contratas), RSC-021 (zona social), RSC-025.	Control de accesos existente + regla de acompañamiento	Jefe de seguridad	PLANIFICADO	C-008, C-025, C-043, C-044, C-046, C-047, C-054 — C-054 (puntos de espera en vía pública) se traza aquí por adaptación declarada: actúa fuera del perímetro propio.
7.3	Seguridad de oficinas e instalaciones	Sí	Despacho del principal y oficina con información Restringida en papel. Refuerzo v1.1: RSC-021 (zona social delimitada sin acceso al resto).	Zonificación y armarios cerrados (PT-08)	Jefe de seguridad	PLANIFICADO	C-046
7.4	Vigilancia de seguridad física	Sí	Existente y eficaz (detectó el eslabón físico del cuasi-incidente fundacional); RSC-009 exige proteger su capa lógica. Refuerzo v1.1: RSC-018 (rondas con puntos de paso), RSC-022 (reconocimiento en destino).	CCTV en red segregada con acceso controlado (PT-07)	Jefe de seguridad	PLANIFICADO	C-004, C-022, C-024, C-030, C-035, C-037 — C-030 (reconocimiento previo en destino) se traza aquí por adaptación declarada: vigila un emplazamiento ajeno, no una instalación de la organización.
7.5	Protección contra amenazas físicas y ambientales	Sí	Ubicación costera; protección de soportes y sistemas ante incendio/inundación. DEUDA v1.1: C-049 (custodia en armario ignífugo) cubre el riesgo de incendio sobre una serie documental concreta, no la protección frente a amenazas físicas y ambientales del conjunto de instalaciones y sistemas, que carece de análisis. La cobertura parcial no cierra la deuda.	Medidas existentes de la finca; revisión en inventario	Jefe de seguridad	PARCIAL	Sin soporte documental
7.6	Trabajo en áreas seguras	Sí	Contratas y mantenimiento en zonas con información o sistemas (RSC-011). Refuerzo v1.1: RSC-020 (mantenimiento acompañado en zonas sensibles).	Acompañamiento y registro (DOC-006 §3)	Jefe de seguridad	PLANIFICADO	C-025, C-043
7.7	Puesto despejado y pantalla limpia	Sí	Oficina con visitas de terceros; papel Restringido a la vista es fuga trivial. Refuerzo v1.1: RSC-023 (retirada del papel Restringido de zonas comunes).	Norma interna + armarios con llave	Jefe de seguridad	PLANIFICADO	C-049
7.8	Ubicación y protección de equipos	Sí	NAS doméstico accesible físicamente en la residencia (RSC-011). Refuerzo v1.1: RSC-024 (inventario físico de equipos y red).	Reubicación del NAS a zona controlada (PT-08)	Jefe de seguridad	PLANIFICADO	C-022, C-064
7.9	Seguridad de activos fuera de las instalaciones	Sí	RSC-012: dispositivos en viaje. Refuerzo v1.1: RSC-019 (custodia del portador de efectivo).	DOC-008 §4	Jefe de seguridad	PLANIFICADO	C-010, C-028, C-040 — C-040 (transporte de efectivo y valores) se traza aquí por adaptación declarada: el efectivo no es un activo de información.

Control	Nombre	Aplica	Justificación (riesgo / requisito que lo exige)	Implementación / referencia	Propietario del control	Estado	Controles (SGSI-REG-001)
7.10	Soportes de almacenamiento	Sí	Discos, USB y papel con información patrimonial; ciclo de vida sin control actual. Refuerzo v1.1: RSC-019 (transporte con acompañamiento), RSC-023 (custodia ignífuga del papel). Alta v1.5: C-050 (destrucción certificada del papel redundante), reasignado desde 7.14 — el papel es soporte de almacenamiento, no equipo.	Inventario de soportes + cifrado de extraíbles	Jefe de seguridad	PLANIFICADO	C-033, C-040, C-049, C-050, C-058, C-060, C-063 — C-040 (transporte de efectivo y valores) se traza aquí por adaptación declarada: el efectivo no es un soporte de información.
7.11	Servicios de suministro	Sí	Cortes de suministro afectan a CCTV y comunicaciones de seguridad. DEUDA v1.1: control declarado aplicable sin soporte documental identificado; pendiente de asignar documento o control en el registro.	SAI y grupo existentes en la finca	Jefe de seguridad	PARCIAL	Sin soporte documental
7.12	Seguridad del cableado	Sí	Instalaciones de terceros (domótica) sin planos actualizados.	Documentación de red con el MSP (PT-07)	Jefe de seguridad	PLANIFICADO	C-022 (PT-07)
7.13	Mantenimiento de equipos	Sí	Contratas de mantenimiento con acceso a sistemas (RSC-011).	DOC-006 T3 + acompañamiento	Jefe de seguridad	PLANIFICADO	DOC-006 §3 (T3)
7.14	Eliminación segura o reutilización de equipos	Sí	Equipos y discos retirados con información familiar (fotos, documentos). La destrucción de soportes en papel se traza a 7.10 desde la v1.5: el papel es soporte de almacenamiento, no equipo.	Anexo contractual del MSP: borrado o destrucción certificada con constancia escrita (DOC-006 §5)	Jefe de seguridad	PLANIFICADO	DOC-006 §5 (anexo MSP)
8.1	Dispositivos de usuario final	Sí	Mezcla actual de dispositivos personales y de trabajo (ESC-001 §6); RSC-003, RSC-012. Retirada v1.5 de C-005: configura la privacidad de un servicio, no la protección de un dispositivo; se traza a 5.10.	Inventario + configuración base + borrado remoto	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-009, C-027
8.2	Derechos de acceso privilegiado	Sí	RSC-008: cuentas privilegiadas del MSP sin control.	Cuentas nominales, MFA, registro de sesiones (PT-07)	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-021
8.3	Restricción de acceso a la información	Sí	NAS y repositorio accesibles hoy desde la red común (RSC-011).	Acceso por rol; NAS segregado (PT-08)	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-026 (PT-08)
8.4	Acceso al código fuente	No	La organización no desarrolla ni custodia código fuente.	—	—	NO APLICA	
8.5	Autenticación segura	Sí	RSC-005, RSC-008, RSC-010: MFA en todo acceso a información Confidencial/Restringida. Refuerzo v1.1: RSC-019 (doble validación de disposiciones de efectivo).	MFA en M365, NAS, CCTV, cuentas del círculo	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-015, C-038, C-059, C-062 — C-038 y C-059 (validación y verificación presencial de disposiciones) se trazan aquí por adaptación declarada: no son mecanismos de autenticación de sistemas.
8.6	Gestión de capacidad	Sí	Menor, pero real: almacenamiento de CCTV y copias dimensionado y vigilado. DEUDA v1.1: control declarado aplicable sin soporte documental identificado; pendiente de asignar documento o control en el registro.	Informe mensual del MSP	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	Sin soporte documental — informe mensual del MSP sin acuerdo escrito que lo exija
8.7	Protección contra malware	Sí	RSC-013: vector de entrada principal del ransomware. DEUDA v1.5: el antimalware existe en los equipos pero ningún documento del SGSI ni control del registro fija su alcance, su actualización ni su supervisión. El anexo del MSP (DOC-006 §5) no lo regula.	EDR gestionado (sustituye antivirus básico)	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	Sin soporte documental
8.8	Gestión de vulnerabilidades técnicas	Sí	RSC-009, RSC-013: cámaras y NAS sin parchear son la vulnerabilidad típica del perfil. Refuerzo v1.1: RSC-024 (línea base de configuración revisada tras parchear).	Parcheo gestionado con informe mensual (PT-10)	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-052
8.9	Gestión de la configuración	Sí	Config. por defecto del M365 y la CCTV = origen de RSC-009. Refuerzo v1.1: RSC-024 (configuración contrastada, no por defecto).	Líneas base documentadas con el MSP	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-052
8.10	Borrado de información	Sí	Retención y borrado de CCTV (privacidad del personal y de invitados) y de información obsoleta.	Política de retención (DOC-002; registro de tratamientos)	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	DOC-002 §5.1
8.11	Enmascaramiento de datos	No	Sin entornos de desarrollo, pruebas ni analítica que traten datos reales; el caso de uso no existe en la organización.	—	—	NO APLICA	
8.12	Prevención de fuga de datos	Sí	Proporcionada al tamaño: reglas anti-reenvío externo y cifrado de adjuntos sensibles en M365; RSC-007, RSC-016. DEUDA v1.1: control declarado aplicable sin soporte documental identificado; pendiente de asignar documento o control en el registro.	Reglas DLP básicas de M365	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	Sin soporte documental
8.13	Copias de seguridad	Sí	RSC-013: copias hoy sin verificar.	3-2-1 con copia offline + prueba semestral (PT-10)	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-032, C-033
8.14	Redundancia de instalaciones de tratamiento	Sí	Cubierta por diseño en cloud (M365); RSC-017 retenido con esta base.	Redundancia del proveedor cloud acreditada por el SLA de servicio; informe de disponibilidad del MSP	MSP, supervisado por el Jefe de seguridad	IMPLEMENTADO	Contrato M365 (SLA de disponibilidad) — sin control del registro: RSC-017 retenido sobre esta base. Excepción declarada a la regla de coherencia de estados (SGSI-REG-001, hoja «Criterios»): control acreditado por contrato de tercero, sin control propio en el registro.
8.15	Registro de eventos	Sí	RSC-008: registro técnico para supervisión del MSP e investigación de incidentes. RSC-018: registro del armado. C-039/C-044 se retiran de este control porque son registros en papel.	Logs de M365, NAS, CCTV; retención 12 meses	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-019, C-024, C-036
8.16	Actividades de supervisión	Sí	Alertas de acceso anómalo a sistemas críticos (CCTV, NAS, correo del principal). Refuerzo v1.1: RSC-018 (alerta si no se arma), RSC-025 (aviso de desviación del vehículo).	Alertas gestionadas por MSP con reporte al jefe de seguridad	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-036, C-055 — C-055 (aviso de desviación de posición del vehículo) se traza aquí por adaptación declarada: supervisa un desplazamiento, no un sistema de información.
8.17	Sincronización de relojes	Sí	Instrumental pero necesario para correlación físico-digital (DOC-009 §5). Retirada v1.5 de C-047 y C-036: registran eventos, no sincronizan relojes. La sincronización horaria común se exige al MSP en el anexo contractual (DOC-006 §5), que es hoy su único soporte.	NTP común exigido al MSP en el anexo contractual (DOC-006 §5)	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	DOC-006 §5 (anexo MSP)
8.18	Uso de utilidades privilegiadas	Sí	Herramientas de administración remota del MSP como vector (RSC-008).	Restricción y registro de herramientas RMM	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-021 (PT-07)

Control	Nombre	Aplica	Justificación (riesgo / requisito que lo exige)	Implementación / referencia	Propietario del control	Estado	Controles (SGSI-REG-001)
8.19	Instalación de software en producción	Sí	Software solo autorizado en equipos corporativos; reduce superficie (RSC-013). DEUDA v1.5: no existe relación de software autorizado ni procedimiento de instalación en producción. El anexo del MSP (DOC-006 §5) no lo regula.	Lista de software autorizado gestionada por MSP	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	Sin soporte documental
8.20	Seguridad de redes	Sí	Red única actual de la residencia = habilitador de RSC-009, RSC-011.	Rediseño de red (PT-07, PT-08)	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-023
8.21	Seguridad de servicios de red	Sí	Requisitos de seguridad en el servicio del MSP y del ISP: acceso remoto únicamente por conexión cifrada autenticada. DEUDA v1.7: el anexo contractual del MSP (DOC-006 §5) que sostenía este control se retiró en DOC-006 v1.5 (verificación cruzada de agosto de 2026); sin soporte documental identificado, pendiente de asignar documento o control en el registro.	Pendiente de asignar (ver HD-01)	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	Sin soporte documental
8.22	Segregación de redes	Sí	Control central del objetivo O7: familia / empleados-invitados / sistemas de seguridad.	Tres segmentos con control de tráfico entre ellos	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-023, C-026
8.23	Filtrado web	Sí	Proporcionado: bloqueo de categorías maliciosas en la red corporativa (anti-phishing, RSC-013). DEUDA v1.1: control declarado aplicable sin soporte documental identificado; pendiente de asignar documento o control en el registro.	Filtrado DNS gestionado	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	Sin soporte documental
8.24	Uso de criptografía	Sí	RSC-007, RSC-012: cifrado en tránsito (canal asesores) y en reposo (dispositivos, NAS).	Canal cifrado; cifrado de disco verificado (DOC-008 V6)	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	C-017, C-027
8.25	Ciclo de vida de desarrollo seguro	No	La organización no desarrolla software.	—	—	NO APLICA	
8.26	Requisitos de seguridad de aplicaciones	No	No desarrolla ni adquiere desarrollo a medida; el software es estándar gestionado por el MSP (cubierto por 5.21-5.23, 8.19).	—	—	NO APLICA	
8.27	Arquitectura e ingeniería de sistemas	No	No diseña sistemas; la arquitectura de red se trata en 8.20-8.22.	—	—	NO APLICA	
8.28	Codificación segura	No	No desarrolla software.	—	—	NO APLICA	
8.29	Pruebas de seguridad en desarrollo	No	No desarrolla software; las pruebas de seguridad de la infraestructura se cubren en 5.35 (verificación independiente).	—	—	NO APLICA	
8.30	Desarrollo externalizado	No	No contrata desarrollo de software. Si la Fase 2 del caso (herramienta de IA) entrara en alcance, este control y los demás excluidos por la misma causa — 8.4, 8.11, 8.25 a 8.29, 8.31 y 8.33— se reactivarían: la exclusión es revisable por diseño (ver Portada).	—	—	NO APLICA	
8.31	Separación de entornos	No	Sin entornos de desarrollo o pruebas.	—	—	NO APLICA	C-052 (PT-15)
8.32	Gestión de cambios	Sí	Cambios del MSP sobre sistemas críticos (red, CCTV) hoy sin control ni aviso.	Cambios relevantes aprobados por el jefe de seguridad	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	
8.33	Información de pruebas	No	Sin entornos de prueba que consuman datos reales.	—	—	NO APLICA	
8.34	Protección de sistemas durante auditorías	Sí	La verificación técnica anual (5.35) debe ejecutarse sin degradar la seguridad de la residencia.	Alcance y ventanas acordados con el jefe de seguridad	MSP, supervisado por el Jefe de seguridad	PLANIFICADO	DOC-010 §2 (programa y reglas de auditoría)

Resumen de aplicabilidad

Controles del Anexo A	93
Aplicables	83
No aplicables	10
IMPLEMENTADO	1
PARCIAL	11
PLANIFICADO	71

Trazabilidad (v1.1)

Aplicables con control en el registro	0
Aplicables cubiertos vía documento	0
Aplicables SIN soporte documental (deuda)	0
Aplicables con otra traza no clasificada	83
Aplicables sin traza alguna	0
COHERENTE (suma de las cuatro categorías «debe igualar «Aplicables»»)	0

Nota de cuadro (v1.2): las cuatro categorías de trazabilidad deben sumar exactamente el número de controles aplicables. En v1.1 sumaban 82 sobre 83: el control 8.6 estaba justificado y con traza, pero su traza —un informe mensual que el MSP remite sin acuerdo escrito que se lo exija— no encajaba en ninguna categoría y se perdía en el recuento. Es la definición exacta de «descansa en una práctica no escrita», así que se reclasifica como deuda documental. La deuda pasa de nueve controles a diez (HD-01). Un resumen que no cuadra con su propio detalle es un resumen que nadie ha comprobado.

Nota de revisión (v1.3): se retira la etiqueta de deuda documental del control 5.23, que está trazado a C-052 y contado entre los aplicables con control en el registro; la etiqueta era un resto de la v1.1 anterior a esa asignación y contradecía tanto este cuadro como la relación de diez controles de HD-01. Se corrige la referencia de retención del control 8.10 (DOC-002 §5.1, no §7) y se declara expresamente el control 8.14 como excepción a la regla de coherencia de estados: está acreditado por contrato de tercero y no tiene control propio en el registro, por lo que la regla del «control menos avanzado» no le es aplicable. Una regla enunciada en términos absolutos con una excepción sin declarar es una regla que no se ha comprobado.